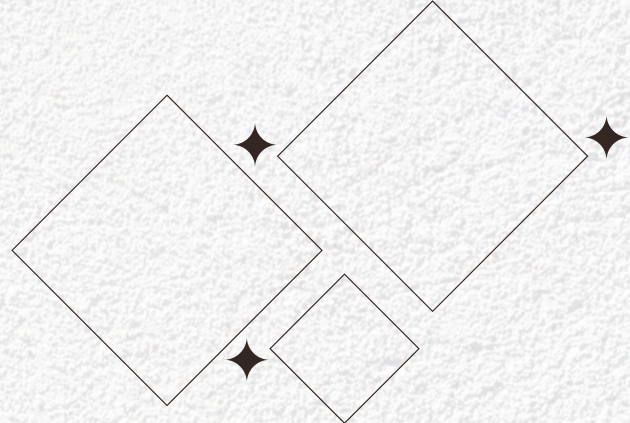


**UNIVERSIDAD
POLITÉCNICA**
DE SAN LUIS POTOSÍ

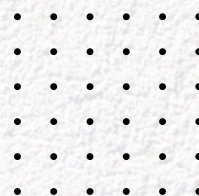
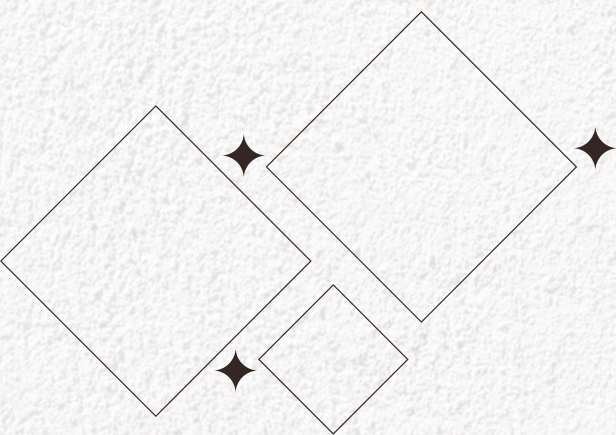


Act4- Una página demasiado convincente

CNO IV Programación WAP

Maestro: Servando López Contreras

Lopez Alcocer Monica Isabel - 179827



Índice

1. Objetivo de la actividad

2. Descripción del escenario

- 2.1 Contexto de la simulación
- 2.2 Descripción del portal institucional ficticio
- 2.3 Elementos utilizados en la página web
- 2.4 Características que simulan un intento de phishing
- 2.5 Restricciones y condiciones del laboratorio

3. Social-Engineer Toolkit (SET)

- 3.1 ¿Qué es Social-Engineer Toolkit?
- 3.2 Principales funciones de SET

4. Credential Harvester Attack Method

- 4.1 ¿Qué es un Credential Harvester?
- 4.2 Funcionamiento del módulo Credential Harvester
- 4.3 Función dentro de una campaña de phishing
- 4.4 Información que puede capturar

5. Configuración del laboratorio

- 5.1 Entorno utilizado
- 5.2 Máquina virtual Kali Linux
- 5.3 Inicio de Social-Engineer Toolkit
- 5.4 Selección del módulo Credential Harvester
- 5.5 Configuración de la página web ficticia
- 5.6 Configuración del servidor local

6. Evidencias y descripción del funcionamiento

- 6.1 Ejecución de SET
- 6.2 Acceso al módulo Credential Harvester
- 6.3 Carga de la página web del laboratorio
- 6.4 Visualización del portal desde el navegador
- 6.5 Introducción de credenciales ficticias
- 6.6 Visualización de la información registrada en Kali Linux

7. Flujo de captura de información

- 7.1 Acceso del usuario al portal ficticio
- 7.2 Introducción de usuario y contraseña
- 7.3 Envío de la información mediante el formulario

8. Identificación de un intento de phishing

9. Cómo prevenir ataques de phishing

10. Controles de seguridad propuestos

11. Conclusión

12. Referencias

1. Objetivo de la actividad

Implementar y analizar, en un entorno de laboratorio controlado, una simulación de ingeniería social mediante Social-Engineer Toolkit (SET), utilizando el módulo Credential Harvester y una página web ficticia. El propósito es comprender el funcionamiento de una técnica de captura de credenciales, reconocer los elementos que permiten identificar un intento de phishing y proponer controles de seguridad orientados a prevenir o reducir su impacto.

2. Descripción del escenario

2.1 Contexto de la simulación

El área de seguridad informática de una organización recibió varios reportes de empleados que aseguran haber recibido un mensaje relacionado con una supuesta actualización de sus credenciales. El mensaje contiene un enlace que dirige a un portal aparentemente institucional, con logotipo, campos de usuario y contraseña y el mensaje “Su sesión ha expirado. Inicie sesión nuevamente para continuar.” A primera vista nada parece fuera de lo común; sin embargo, el portal no pertenece a la organización, sino a un atacante que busca capturar las credenciales.

2.2 Descripción del portal institucional ficticio

Para no suplantar ningún servicio real, se diseñó un portal completamente ficticio: “NexoPlay”, una supuesta plataforma de videojuegos gratuitos. La marca y todo su contenido son inventados y no representan a ninguna empresa o institución existente, cumpliendo las restricciones del laboratorio.

2.3 Elementos utilizados en la página web

El portal simula un sistema de autenticación e incluye: nombre del sistema (NexoPlay), campo de usuario, campo de contraseña, botón de inicio de sesión, mensaje de expiración de sesión y un indicador visual de confianza (“Conexión segura”).

2.4 Características que simulan un intento de phishing

La página reúne los rasgos típicos de un sitio fraudulento: apariencia profesional y cuidada que genera confianza, un mensaje de urgencia (la sesión expirada que empuja a actuar de inmediato), un indicador de seguridad falso y un formulario cuyo verdadero fin es recolectar las credenciales del usuario.

2.5 Restricciones y condiciones del laboratorio

La práctica se realizó bajo condiciones controladas. Durante la actividad no se utilizaron páginas ni credenciales reales, no se clonaron portales de instituciones o empresas, no se publicó el servidor hacia Internet, no se emplearon dominios externos ni técnicas de suplantación DNS, y no se instalaron payloads ni se ejecutó código malicioso. Todo el ejercicio se llevó a cabo en una máquina virtual aislada y con datos de prueba ficticios.

3. Social-Engineer Toolkit (SET)

3.1 ¿Qué es Social-Engineer Toolkit?

Social-Engineer Toolkit (SET) es un framework de código abierto desarrollado por TrustedSec (creado por David Kennedy), orientado a pruebas de penetración centradas en la ingeniería social. Automatiza la creación de escenarios de ataque que aprovechan el factor humano en lugar de vulnerabilidades técnicas. Viene preinstalado en Kali Linux; en esta práctica se utilizó la versión 8.0.3.

3.2 Principales funciones de SET

Entre sus módulos destacan los vectores de spear-phishing, los vectores de ataque a sitios web (donde se encuentra el Credential Harvester), el generador de medios infecciosos, la creación de payloads y listeners, el envío masivo de correos (Mass Mailer) y la generación de códigos QR. Es una herramienta de uso educativo y profesional para evaluar qué tan resistentes son los usuarios ante intentos de ingeniería social.

4. Credential Harvester Attack Method

4.1 ¿Qué es un Credential Harvester?

Un Credential Harvester (“cosechador de credenciales”) es un servidor web falso que muestra una página de inicio de sesión de apariencia legítima con el único fin de capturar y registrar los datos que la víctima escribe en el formulario.

4.2 Funcionamiento del módulo Credential Harvester

SET aloja la página (que puede ser importada, tomada de una plantilla o clonada) y reescribe el formulario para que, al enviarse, los datos viajen por HTTP POST hacia el propio servidor de SET. Este los intercepta, los muestra en consola y los guarda en un reporte; normalmente redirige después al sitio legítimo para no levantar sospechas.

4.3 Función dentro de una campaña de phishing

Dentro de una campaña de phishing, el Credential Harvester es el “destino” del engaño: mientras el correo o el enlace convincente atraen a la víctima, esta página es la que convierte ese clic en credenciales robadas. Es el componente que materializa el robo de información.

4.4 Información que puede capturar

Puede capturar cualquier campo que el formulario envíe por POST. En esta práctica se registraron el usuario, la contraseña y el parámetro adicional “remember”, todos en texto plano.

5. Configuración del laboratorio

5.1 Entorno utilizado

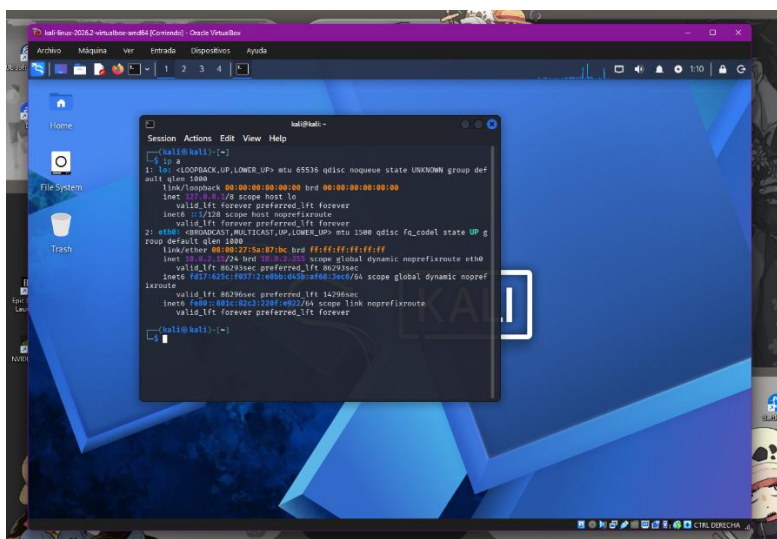
Equipo anfitrión con Windows y Oracle VirtualBox como plataforma de virtualización. La máquina virtual utiliza un adaptador de red en modo NAT, lo que la mantiene aislada y sin exposición hacia Internet.

5.2 Máquina virtual Kali Linux

Se empleó Kali Linux 2026.2. La dirección IP de la máquina se obtuvo con el comando `ip a`, resultando **10.0.2.15**. Antes de iniciar se detuvo el servicio Apache con `sudo systemctl stop apache2` para liberar el puerto 80, y se verificó la instalación de SET con `which setoolkit`.

5.3 Inicio de Social-Engineer Toolkit

SET se ejecutó con permisos de administrador mediante `sudo setoolkit`, ya que el servidor web requiere el puerto 80.



5.4 Selección del módulo Credential Harvester

Dentro de SET se siguió la ruta:

- 1) Social-Engineering Attacks
- 2) Website Attack Vectors
- 3) Credential Harvester Attack Method
- 3) Custom Import.

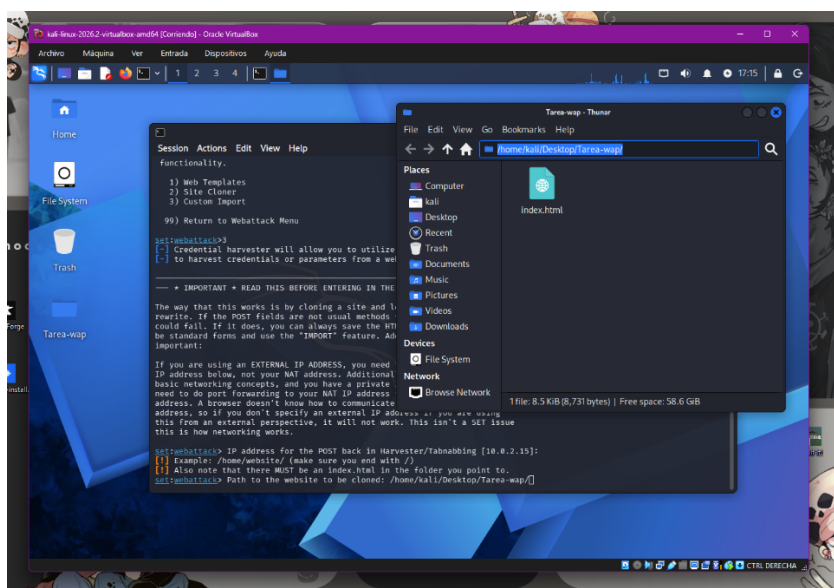
Se eligió “Custom Import” para utilizar la página ficticia propia, en lugar de clonar un sitio real o usar plantillas de servicios existentes.

5.5 Configuración de la página web ficticia

El archivo `index.html` del portal NexopPlay se colocó en la carpeta `~/Desktop/Tarea-wap`. Se indicó esta ruta a SET y, al detectar el archivo, se seleccionó la opción “Copy just the index.html”. Como toda la hoja de estilos está incluida dentro del propio archivo, la página se muestra completa.

5.6 Configuración del servidor local

Se estableció la dirección de POST back en **10.0.2.15** y la URL importada como `http://10.0.2.15`. SET levantó el Credential Harvester en el puerto 80, quedando a la espera de la información enviada.



6. Evidencias y descripción del funcionamiento

6.1 Ejecución de SET

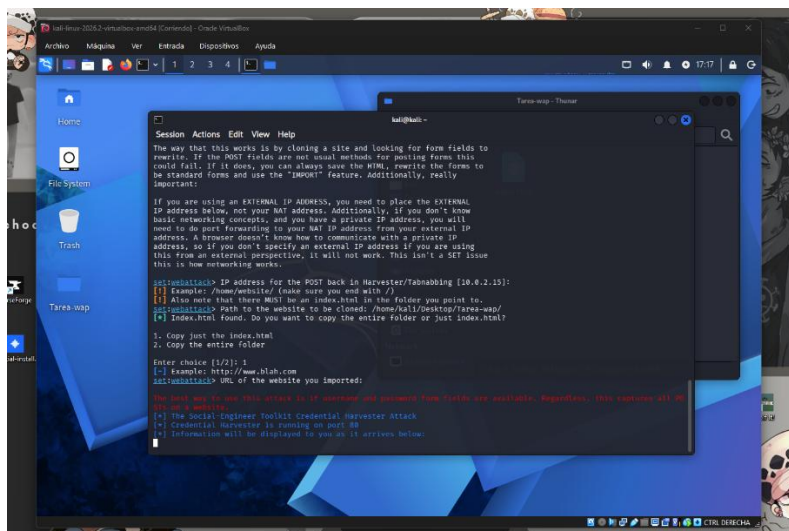
Se muestra el inicio de Social-Engineer Toolkit con su banner y el menú principal de ataques.

6.2 Acceso al módulo Credential Harvester

Se accede a los vectores de ataque web y se selecciona el método Credential Harvester con la opción Custom Import.

6.3 Carga de la página web del laboratorio

SET copia el index.html indicado y confirma que el Credential Harvester está corriendo en el puerto 80.

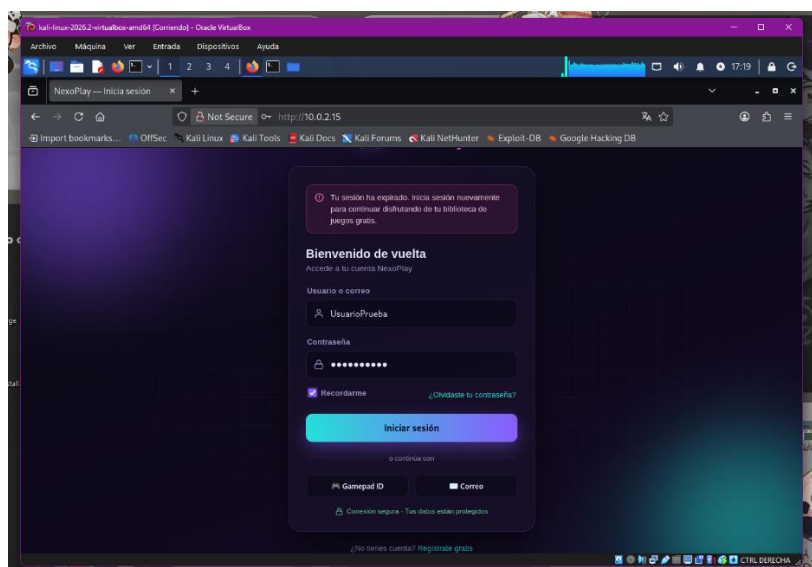


6.4 Visualización del portal desde el navegador

Al abrir <http://10.0.2.15> en el navegador de la máquina, se muestra el portal Nexoplay con el mensaje de sesión expirada.

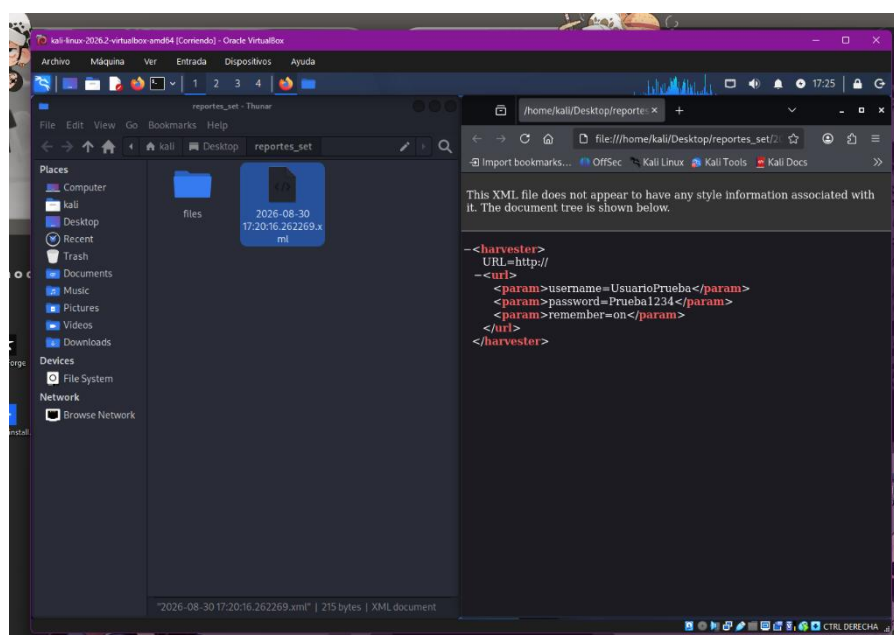
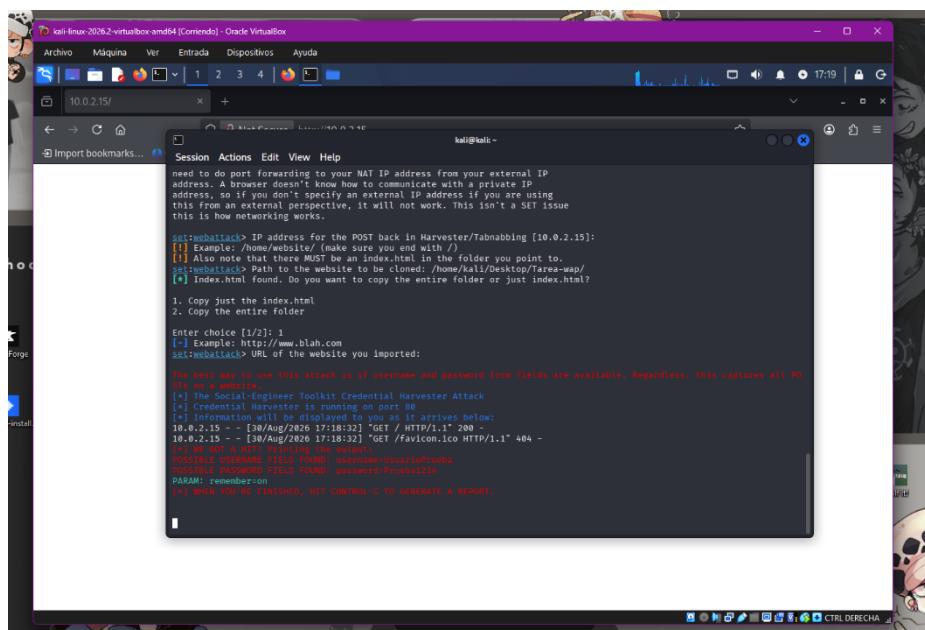
6.5 Introducción de credenciales ficticias

Se ingresaron datos de prueba inventados en el formulario (usuario: UsuarioPrueba) y se envió el inicio de sesión.



6.6 Visualización de la información registrada en Kali Linux

En la terminal de SET aparecieron los datos capturados: **username=UsuarioPrueba** y **password=Prueba1234**, junto con el parámetro **remember=on**. Al detener el servidor, SET generó un reporte en formato XML con la misma información.



7. Flujo de captura de información

7.1 Acceso del usuario al portal ficticio

El usuario abre la dirección del portal y su navegador solicita la página al servidor de SET, que la entrega como si fuera un sitio legítimo.

7.2 Introducción de usuario y contraseña

Confiando en la apariencia de la página y en el mensaje de urgencia, el usuario escribe su nombre de usuario y su contraseña en el formulario.

7.3 Envío de la información mediante el formulario

Al presionar el botón de inicio de sesión, la información del formulario es enviada al servidor donde se encuentra ejecutándose SET. Credential Harvester recibe los parámetros, los muestra en la terminal y permite almacenarlos en un reporte.

De manera simplificada, el proceso observado fue:

Usuario → Página ficticia → Formulario → Servidor local → Credential Harvester → Reporte

8. Identificación de un intento de phishing

Un usuario puede detectar posibles intentos de phishing prestando atención a diferentes señales. Entre ellas se encuentran direcciones web extrañas o diferentes a las oficiales, mensajes que generan urgencia, solicitudes inesperadas de contraseñas, errores de diseño o redacción y páginas que no utilizan una conexión segura.

En la simulación, se identificaron varios indicadores que permiten reconocer una página potencialmente fraudulenta:

- La dirección no corresponde a un dominio institucional: se muestra una IP suelta (10.0.2.15) en lugar de un dominio oficial.
- El navegador marca la conexión como “Not Secure” (sin HTTPS válido), pese a que la página presume estar protegida.
- El indicador “Conexión segura” es solo texto dentro de la página, no el candado real del navegador.
- Se genera una sensación de urgencia (“Tu sesión ha expirado”) para forzar una acción rápida.
- Se solicitan credenciales de forma inesperada a partir de un enlace no verificado.

9. Cómo prevenir ataques de phishing

La mejor protección contra el phishing combina buenas prácticas de los usuarios con controles tecnológicos. Antes de introducir una contraseña se debe verificar cuidadosamente la dirección del sitio web y evitar iniciar sesión mediante enlaces sospechosos recibidos por correo, mensajes o redes sociales.

También es recomendable utilizar autenticación multifactor (MFA), contraseñas diferentes para cada servicio y gestores de contraseñas. Ante mensajes que afirmen que una cuenta será suspendida o que es necesario actuar inmediatamente, es preferible ingresar al servicio escribiendo manualmente su dirección oficial en el navegador.

La capacitación de los usuarios también es fundamental, ya que permite reconocer señales de ingeniería social antes de proporcionar información sensible.

10. Controles de seguridad propuestos

- Autenticación multifactor (MFA): aunque se roben la contraseña, no basta para acceder.
- Uso obligatorio de HTTPS con certificados válidos en los portales legítimos.
- Filtrado de correo y de URLs maliciosas a nivel de red y de servidor.
- Configuración de SPF, DKIM y DMARC para dificultar la suplantación de correo.
- Programas de concientización y simulacros de phishing para los usuarios.
- Monitoreo de accesos anómalos y políticas de contraseñas robustas.

11. Conclusión

La práctica permitió comprender de forma directa cómo una página web aparentemente legítima puede utilizarse para solicitar información sensible y cómo herramientas como Credential Harvester permiten visualizar los datos enviados mediante un formulario.

El ejercicio también demuestra que el aspecto visual de una página no es suficiente para determinar si un sitio es confiable. Es necesario revisar la dirección web, el tipo de conexión y el contexto en el que se solicita la información.

Finalmente, la actividad resalta la importancia de la concientización en ciberseguridad, la autenticación multifactor y la verificación de los sitios antes de proporcionar credenciales. Herramientas como SET resultan útiles para fines educativos y pruebas autorizadas, siempre que se utilicen dentro de ambientes controlados.

12. Referencias

- TrustedSec. Social-Engineer Toolkit (SET). <https://github.com/trustedsec/social-engineer-toolkit>
- Kali Linux. Documentación oficial. <https://www.kali.org/docs/>
- OWASP Foundation. Phishing. <https://owasp.org/>
- Kennedy, D. et al. The Social-Engineer Toolkit (SET) User Manual, TrustedSec.